

DNS の不正使用手法のマトリックス

FIRST DNS Abuse Special Interest Group

<https://www.first.org/global/sigs/dns>

はじめに

本レポートは、FIRST の [DNS Abuse SIG\(Special Interest Group\)](#)によるもので、DNS の不正使用(DNS Abuse)を伴うインシデントに対応するインシデント対応チームに向けたアドバイスを提供します。何が DNS の不正使用で、何がそうでないかの境界を歯切れ良く定義することは難しい。多くの組織が DNS の不正使用の定義に関して、フィッシング、マルウェア、迷惑メール、ボットネット、詐欺の何らかの組み合わせに関するもの、あるいはこれらの不正使用方法の一部またはすべての組み合わせに関連するもの、などの議論を重ねてきた。FIRST DNS Abuse SIG は、これらの分類は実用的なアドバイスをインシデント対応者に与えてはいないと認識している。そこで本レポートは、インシデント対応者やセキュリティチームが目にするであろうインシデントで使用される手法の一般的な例を提示すること、また不正使用で使用される特定の手法をインシデント対応者が検知、緩和、抑止するうえで手助けとなりえるステークホルダーのリストを提供することにより、DNS の不正使用の調査・研究における既存の取組を補完することを目標とする。

現在、アドバイスは、特定のステークホルダーが特定の手法に関して直接支援できるかどうかを示すマトリックスの形で与えられる。ここでの「支援」とは、そのステークホルダーが不正使用手法を検知、緩和、抑止できる立場にあるかどうかを意味する。この情報を、インシデント対応行動(検知、緩和、抑止)を網羅する3つのスプレッドシートにまとめた。例えば、DNS キャッシュポイズニングを伴うインシデントの際、緩和のスプレッドシートに移動して DNS キャッシュポイズニングの行を参照すれば、インシデント緩和の支援を得るために連絡できるステークホルダーを見つけることができる。

DNS エコシステムは複雑で、多数のステークホルダーと運用モデルが存在する。リストに挙げられた不正使用手法の中には無害な使用法も存在するので、「これらの手法は絶対に許容されるべきではない」というほど単純なものではない。しかし、インシデント対応の文脈ではインシデントが発生しているという前提があるので、攻撃者がインシデントを仕掛けるまたは維持するために使用した手法が何であれ、それらは悪意あるものか、組織のセキュリティポリシーに違反するか、あるいはその両方にあてはまる。インシデント対応者は、[権限範囲内](#)で責任を持って証拠保全を行うということに徹するべきである。DNS Abuse SIG は、リストに挙げられた手法のいずれかが一般に DNS の不正使用にあたるものであるかどうかの判断は示さない。本レポートは、特定のインシデントにおいて、ある手法が悪意を持って使用されているとの前提で、インシデントを検知、緩和、抑止する行動ができるのは誰なのかを明らかにするという観点から構成されている。

DNS が関与する攻撃と並行して、いくつかの手法が使用される場合がある。例えば BGP ハイジャックや TLS 証明書のなりすましといったものである。これらの手法は対象範囲外とし、本文書は DNS の不正使用手法にだけ焦点を当てる。

本文書のこのバージョンには含まれていないが、インシデント対応の際に連絡可能な他のポリシー関連、政府、司法の関係組織があることに留意しておくとうりだろ。例えば、サイバー犯罪に関する条約や他の国際協定には、国境を越えた証拠の押収とインフラの一時停止をどちらも行える仕組みがある。外国の法執行機関の捜査官が行う作業の第 1 段階は、大抵の場合、正式な法(刑事共助条約)に基づく要請が保留されている間にデータが消失しないようにするための非公式な保全要請になるだろ。

用語

3 次元マトリックス(行動、手法、ステークホルダー)では、以下で定義する用語を使用する。

行動

以下の定義において、CSIRT が提供している可能性のあるサービスについては、FIRST CSIRT サービスフレームワーク v2.1 と連動している。

- **検知** – インシデントの可能性ある事象を特定する。サービス: [監視と検知](#)、[インシデント報告の受理](#)。
注: インシデント管理において、インシデント対応(IR)チームが追加の検知ツールやシグネチャの確認、収集を望む段階は、緩和段階であり検知段階ではない。検知行動は、インシデントの最初の検知のみに焦点を当てている。
- **緩和** – インシデントを封じ込め、安全な運用を回復させる。サービス: [緩和と復旧](#)。
- **抑止** – DNS 固有の作業手順を適用し、将来におけるこの種のインシデントの発生確率を下げる。サービス: [知識の移転\(組織内 IT チームへの移転も含む\)](#)、[脆弱性対応](#)。検知にも関連し(おそらくはシグネチャや検知ルールの更新)、復旧にも関連する(復旧作業時、再発防止のためにシステムを再設定する場合)。広範なマルウェア抑止は本文書の対象範囲外であることに注意して欲しい。もちろん、広範なマルウェア対策は誰もが行うべきである。例えば、[M3AAWG](#) によるベストプラクティスを参照。

手法

1. DGA (ドメイン生成アルゴリズム) – 詳細については <https://attack.mitre.org/techniques/T1568/002/> 参照。

2. ドメイン名の侵害 – ドメイン名の正当な保有者から管理権限を不当に奪う。侵害されたドメインは、さまざまな悪意ある行為、例えば SPAM の送信、フィッシング、マルウェアの配布、ボットネットのコマンド & コントロール(C2)などに使用される可能性がある。詳細については <https://www.icann.org/groups/ssac/documents/sac-007-en> 参照。
3. lame delegation (レイムデレゲーション) – ネームサーバーのドメインの有効期限が切れると lame delegation が発生する。攻撃者は期限が切れたネームサーバーのドメインを再登録することにより、そのドメインの管理権限を得られる。詳細については <https://blog.apnic.net/2021/03/16/the-prevalence-persistence-perils-of-lame-nameservers/> 参照。
4. DNS キャッシュポイズニング – DNS スプーフィングとも呼ばれる。サイバー攻撃の一種で、攻撃者が偽の DNS レコードを注入することによって DNS リゾルバーのキャッシュを汚染し、攻撃者に制御されたレコードをリゾルバーに保存させる。詳細については <https://capec.mitre.org/data/definitions/142.html> 参照。
5. DNS リバインディング – 悪意ある Web サイトがクライアントをローカルネットワークアドレスに誘導し、攻撃者が同一生成元ポリシーを迂回して被害者のローカルリソースへのアクセスを得られるようにする。詳細については <https://capec.mitre.org/data/definitions/275.html> 参照。
6. DNS サーバーの侵害 – 攻撃者が、オープン再帰 DNS サーバー、権威 DNS サーバー、組織の再帰 DNS サーバー、ISP が運用する再帰 DNS サーバーなどの管理者権限を取得する。
7. スタブリゾルバーのハイジャック – 攻撃者が、DNS 問い合わせを傍受して不正な応答または悪意ある応答を返す悪意あるコードにより、コンピューターや携帯電話のオペレーティングシステムを侵害する。
8. ローカルな再帰リゾルバーのハイジャック – 家庭用ルーターなどの顧客構内設備(CPE)は、しばしばローカルネットワークに対して DNS 再帰検索サービスを提供する。CPE 機器が侵害されると、攻撃者は応答を改変するなどして再帰リゾルバーの振る舞いを換えられるようになる。
9. オンパス(on-path)の DNS 攻撃 – 攻撃者がユーザーと DNS サーバー間の通信を傍受し、悪意あるサイトを指し示す異なる宛先 IP アドレスを指定する。(<https://www.imperiva.com/learn/application-security/dns-hijacking-redirect/>)
10. DNS に対する DoS – ターゲットの DNS サーバーに対して複数のシステムが悪意あるトラフィックを同時に送信する。
11. DoS を目的とした DNS サーバーの不正使用 – 攻撃者は、大量のネットワークトラフィックをターゲットに反射させることで、サービス妨害を引き起こそうと試みることがある。この種のネットワーク DoS は、サー

ビスをホストしており、偽装された送信元 IP アドレスに応答する第三者のサーバーを仲介者として利用する。このサーバーは、一般にリフレクターと呼ばれる。攻撃者は、被害者のアドレスに偽装されたパケットをリフレクターに送信することにより、リフレクション攻撃を達成する。反射・増幅・フラッドを可能にしたプロトコルでは、DNS と NTP の 2 つが突出しているが、他にもいくつかのプロトコルが実世界で使用されたと文書に記録されている。これらの反射や増幅によるフラッドを権威 DNS サーバーのような DNS の構成要素に誘導すれば、それらを応答不能にできる。[\(https://attack.mitre.org/techniques/T1498/002/\)](https://attack.mitre.org/techniques/T1498/002/)

12. 動的な DNS 解決による検知の難化 – 攻撃者は、一般的な検知・修正を回避するため、コマンド&コントロールインフラへの接続を動的に確立する場合がある。これは、攻撃者がマルウェアからの通信を受信するために使用するインフラとマルウェアの間で、共通のアルゴリズムを使用することで達成できる。これらの演算を使用して、マルウェアがコマンド&コントロールと通信するために使用するドメイン名、IP アドレス、ポート番号などを動的に調整することができる。[\(https://attack.mitre.org/techniques/T1568/\)](https://attack.mitre.org/techniques/T1568/)
13. 動的な DNS 解決(Fast flux)による隠ぺい – 攻撃者は、Fast flux DNS を使用して、単一のドメイン解決に割り当てられた素早く変化する多数の IP アドレス群の中にコマンド&コントロールチャネルを隠ぺいする場合がある。この手法は、完全修飾ドメイン名(FQDN)と、そのドメイン名に割り当てられた複数の IP アドレスを使用する。これらの IP アドレスは、ラウンドロビン機能と DNS リソースレコードの短い TTL(Time-To-Live)を組み合わせることで、高い頻度で入れ替わっていく。
[\(https://attack.mitre.org/techniques/T1568/001/\)](https://attack.mitre.org/techniques/T1568/001/)
14. DNS を介した情報の不正な持ち込みおよび持ち出し – DNS を介した不正な情報の持ち出しは、委任されたドメインを必要とする。パブリック DNS 内にドメインが存在しない場合は、ドメインのゾーンファイル情報があらかじめロードされており、侵害された機器が送信する問い合わせを受信して応答するように設定されたリゾルバーの運用が必要となる。
15. (実効的)セカンドレベルドメインの悪意ある登録 – 例えば、攻撃者が被害者を攻撃する前に、ターゲティング時に使用できるように、ICANN が認定したレジストラーからドメインを購入する、あるいはレジストラーにドメインを登録する。[CAPEC-630](#) も参照。
16. ダイナミック DNS プロバイダーを介した悪意あるサブドメインの作成 – 攻撃者が被害者を攻撃する前に、レジストリやレジストラー以外で自分が保有、管理をしているドメイン下位のサブドメインを提供しているエンティティからドメインを購入する、あるいはそこでドメインを作成する。
https://en.wikipedia.org/wiki/Dynamic_DNS も参照。
17. DNS の不正使用を目的とした DNS 以外のサーバーの侵害 – インターネット攻撃のインフラは多岐にわたり、そこには DNS 以外のあらゆるサーバーが含まれる。侵害された多数のサーバー、例えば Web サーバーやメールサーバーなどは DNS とのやり取りを行っており、DNS の不正使用の実施に関与することがある。例えば、フィッシングメールの送信に使用される可能性がある方法の 1 つに、メールサーバーの侵害が挙げられる。

18. 未登録ドメイン名を介したなりすまし - ドメイン名が期待されるコンテキスト(メールの From ヘッダー、Web ページやメール本文に含まれる URL など)において、**攻撃者が管理しておらず、正当な登録者も管理していないまたは登録していないドメイン名を指定する。**
19. 登録されたドメイン名のなりすまし - ドメイン名が期待されるコンテキスト(メールの From ヘッダー、Web ページやメール本文に含まれる URL など)において、攻撃者は管理していないが、**実際に正当な登録者が管理しているかまたは登録したドメイン名を指定する。**
20. DNS トンネリング - DNS 上での他のプロトコルのトンネリング - DNS プロトコルは、コンピューターネットワークにおいて管理機能を提供しているため、環境の中では極めて一般的なものだろう。DNS トラフィックは、ネットワーク認証の完了前でも許可される場合がある。DNS パケットは多数のフィールドとヘッダーを含んでいるので、そこにデータを隠すことができる。しばしば DNS トンネリングとして知られるように、攻撃者は DNS を不正使用し、通常予期されるトラフィックに偽装して、被害者ネットワーク内にある攻撃者の管理下のシステムと通信する可能性がある。(<https://attack.mitre.org/techniques/T1071/004/>)
21. DNS ビーコン - C2 との通信 - データを不正に持ち出すか C2 からのさらなるコマンドを待機するため、コマンド&コントロールサーバーに DNS 問い合わせを連続的または定期的に送信する。

ステークホルダー

多くの組織は、さまざまな状況に応じてそれぞれ異なるステークホルダーの役割を果たす場合がある。また中小規模の組織では、同じ個人がさまざまな状況で異なる役割を果たす場合がある。しかし、これらのさまざまなステークホルダーはそれぞれ異なる能力を保持することから、別個のものとして体系化した。ある組織が、それぞれ異なるステークホルダーの役割を果たすチームを複数保持する場合であっても、ステークホルダーの能力を実行するチームに連絡を試みるのが有用だろう。

インシデント対応者は、すべてのステークホルダーが対応者のために思ってくれるわけではないことに留意しておくことが重要である。連絡を受けたステークホルダーは、注意散漫であったり、未熟であったり、最悪の場合には不正使用をサポートするインフラを意図的に運用していたりするかもしれない。後者を行っている組織は、よくても連絡に対して受容的ではなく、最悪の場合は欺瞞に満ちたものになる。ステークホルダーとの連絡を進めるべきかどうか判断できない場合、同僚と一緒に確認することを勧める。

1. レジストラ - TLD 下位へのドメイン登録を許可する組織 - 詳細については <https://www.icann.org/en/icann-acronyms-and-terms/registrar-en> 参照。
2. レジストリ - TLD に関するドメインのデータベースを維持する責任を負う組織 - 詳細については <https://www.icann.org/en/icann-acronyms-and-terms/registry-en> 参照。
3. 権威 DNS サーバー運用者 - 詳細については <https://www.icann.org/en/icann-acronyms-and-terms/authoritative-name-server-en> 参照。

4. ドメイン名リセラー - 詳細については <https://www.icann.org/resources/pages/reseller-2013-05-03-en> 参照。
5. 再帰リゾルバー運用者 - プライベート再帰リゾルバーまたはパブリック再帰リゾルバーを運用する組織。
6. ネットワーク運用者 - AS の運用組織。この能力を持つ組織は、再帰 DNS サーバーを稼働させていないものと想定する。この列は、ネットフローの情報(送信元/宛先 IP アドレス、L3 プロトコル、送信元/宛先ポート番号など)や BGP ルーティングデータを意味し、パッシブ DNS は除外する(明確化のため)。
7. アプリケーションサービスプロバイダー - (Google Docs のような)SaaS(Software as a Service)プロバイダー。SaaS の定義については <https://www.iso.org/obp/ui/#iso:std:iso-iec:17788:ed-1:v1:en> 参照。
8. ホスティングプロバイダー - インターネットホスティングサービスを提供する会社。インターネットホスティングサービスとは、インターネットに接続されたサーバーを運営し、組織や個人がインターネットに接続されたコンテンツを提供したり、サービスをホストしたりできるようにするサービスである。詳しくは、https://en.wikipedia.org/wiki/Internet_hosting_service 参照。
留意:ホスティングプロバイダーが防弾ホスティングである場合や攻撃インフラの提供に加担している場合、連絡したとしても、よくて何も得るものはなく、最悪の場合チームが報復に晒されることになる。
9. 脅威インテリジェンスプロバイダー - 脅威インテリジェンスプロバイダーは、意思決定プロセスに必要なコンテキストを提供するため、インテリジェンスの集約、変換、分析、解釈、高品質化などを行う。サイバー脅威インテリジェンス(CTI)は共有と分析のみが行われるものとする。
10. 機器、OS、アプリケーションソフトウェアの開発者 - DNS リゾルバーソフトウェアのコードを書くまたは開発をしているソフトウェア開発者、またはソフトウェアプロジェクトにインポートされる DNS リゾルバーのパッケージを更新する責任を負う人。
11. ドメイン登録者 - ドメイン名を登録した個人またはエンティティ。詳細については <https://www.icann.org/en/icann-acronyms-and-terms/registrant-en> 参照。悪意ある登録の行におけるドメイン登録者の列では、このステークホルダーは、悪意ある登録を行った実在の人物としてモデル化されている。
12. エンドユーザー - インターネットを利用するすべての人々(列挙されている他のステークホルダーのいずれの能力も持たない人)。
13. 法執行機関および公安機関 - 法の執行または公益のために行動する権限を持つ政府組織。そのような組織が問題に気付くのは、通常、以下のような理由による。

- a. 進行中の捜査において、法執行機関の手法により独自の洞察が得られる。
 - b. 被害者の告発が不正使用を示す情報を提供すると、大抵の場合、組織は技術的領域の専門家の協力を得てその証拠を理解する。
14. CSIRT / ISAC – [コンピューターセキュリティインシデント対応チーム / 情報共有・分析センター](#)。この列は、チームやセンターの能力だけをモデル化している。各 CSIRT や ISAC はサービスのエンドユーザーでもあり、ドメイン登録者でもあることに加えて、脅威インテリジェンスプロバイダーなどである場合もある。CSIRT や ISAC が(組織として)ステークホルダーの能力を提供している場合に、これらの列を使用する。
15. インシデント対応者 – 影響を受けている組織内部の[コンピューターセキュリティインシデント対応チーム](#)。

不正手法の例

SIG はさまざまな不正手法の例を収集し、FIRST.org の Web サイトの DNS Abuse SIG ホームページで閲覧可能になっている。

<https://www.first.org/global/sigs/dns/dns-abuse-examples>

手法の例のリストは、より多くの情報が収集、整理された段階で、継続的に更新されていく予定である。

JPCERT/CC は、ドメイン生成アルゴリズム(DGA)や、実効的 SLD の悪意ある登録などの手法例を実証する[フィッシング URL のリスト](#)を公開している。

Nominet は、[DNS の dangling](#) エントリーがどのように lame delegation やオンパスの DNS 攻撃といった手法につながる脆弱性をもたらすかの解説を公開している。

米国歳入庁(IRS)は、攻撃対象の組織に関する悪意ある登録やなりすましを利用した[SMS 詐欺に対する注意](#)を公開している。

インシデント対応者へのアドバイス

以下のスプレッドシートは、さまざまな DNS の不正使用手法に対するさまざまなインシデント対応段階において、どのような組織に連絡するのが生産的かという点について我々のアドバイスを提示するものである。サイバー犯罪に関する条約や他のネットワークには、国境を越えた証拠の押収とインフラの一時停止をどちらも行える仕組みがある。条約は例えば、「外国の法執行機関の捜査官が行う作業の第 1 段階は、大抵の場合、正式な法(刑事共助条約)に基づく要請の保留中にデータが消失しないようにするための非公式な保全要請になる」といったことを期待している。

不正使用手法のマトリックス

記号一覧

✔ : エンティティは脅威を検知/緩和/抑止する能力を保持している

✘ : エンティティは脅威を検知/緩和/抑止する能力が無い

- DGA: ドメイン生成アルゴリズム
- eSLD: 実効的セカンドレベルドメイン
- pDNS: パッシブ DNS

検知

🟢 : エンティティは検知する能力を保持している

🔴 : エンティティは検知する能力が無い

	レジストラー	レジストリ	権威 DNS サーバー運 用者	ドメイン名 リセラー	再帰リゾルバー運用者	ネットワーク 運用者	アプリケー ションサービ スプロバイ ダー	ホスティング プロバイダー	脅威インテ リジェンスプ ロバイダー	機器、OS、 アプリケーションソフト ウェアの開 発者	ドメイン登録者	エンドユーザー	法執行機および 公安機関	CSIRTs / ISACs	インシデント対応者
DGA (ドメイン生 成アルゴリズム)	🟢 (eSLD のみ。ドメイン 作成時点および存在 中に分析を行っている 場合)	🟢 (eSLD のみ)	🟢 (eSLD の み。顧客の ドメインの分 析を行って いる場合)	🟢 (eSLD のみ)	🟢 (再帰リゾルバーでログ イングまたは pDNS によ るログイングと分析を行っ ている場合)	🔴	🟢	🔴	🟢	🔴	該当なし (登録者が脅威ア クターそのもの)	🔴	🟢 (レジストリか、 PSWG および GAC のどちらか あるいは両方に 関与を要請可能)	🔴	🟢 (送出される問い合わせが ログイングされている場 合)
ドメイン名の侵害	🟢	🟢	🔴	🟢	🟢 (DNS RPZ を使用し、脅 威インテリジェンスを反 映している場合)	🔴	🔴	🔴	🟢	🔴	🟢 (事前防御的監視 を行っている場 合)	🔴	🟢	🔴	🔴 (組織外のドメインを想 定)
lame delegation (レイムデレゲー ション)	🔴	🟢	🔴	🔴	🟢	🔴	🔴	🔴	🟢	🔴	🟢 (事前防御的監視 を行っている場 合)	🔴	🔴	🔴	🔴 (組織外のドメインを想 定)
DNS キャッシュポ イズニング	🔴	🔴	🔴	🔴	🟢 (再帰リゾルバーで DNSSEC 署名検証を行 い RFC 8914 規定の拡 張エラーを有効にして いる場合)	🟢 (NetFlow/ Zeek 等によ るトラフィッ ク分析を行 っている場 合)	🔴	🔴	🟢	🔴	🟢 (事前防御的監視 を行っている場 合)	🔴	🔴	🔴	🔴 (外部のリゾルバーが汚 染されたと想定)
DNS リバインディ ング	🔴	🔴	🔴	🔴	🟢 (pDNS 分析により、パ ブリック IP アドレスから RFC 1918 アドレスに変 化した DNS 応答を検知 可能)	🟢 (NetFlow/ Zeek 等によ るトラフィッ ク分析を行 っている場 合)	🔴	🔴	🟢	🔴	🟢 (事前防御的監視 を行っている場 合)	🔴	🔴	🔴	🟢

	レジストラー	レジストリ	権威 DNS サーバー運 用者	ドメイン名 リセラー	再帰リゾルバー運用者	ネットワーク 運用者	アプリケー ションサービ スプロバイ ダー	ホスティング プロバイダー	脅威インテ リジェンスプ ロバイダー	機器、OS、 アプリケー ションソフト ウェアの開 発者	ドメイン登録者	エンドユーザー	法執行機および 公安機関	CSIRTs / ISACs	インシデント対応者
DNS サーバーの 侵害	✖	✖	✔ (権威サーバ ーが侵害さ れた場合)	✖	✔ (再帰リゾルバー自身が 侵害された場合)	✖	✔	✖	✔	✖	✖	✖	✖	✖	✖ (侵害前の pDNS ログが 存在しない場合)
スタブリゾルバー のハイジャック	✖	✖	✖	✖	✖	✖	✖	✖	✔	✔	✖	✔ (おそらくはアンチ ウイルスソフトウェ ア次第)	✖	✖	✔
ローカルな再帰リ ゾルバーのハイジ ャック	✖	✖	✖	✖	✖	✔ (NetFlow/ Zeek 等によ るトラフィッ ク分析を行 い、脅威イン テリジェン スの提供を 受けている 場合)	✖	✖	✔	✔	✖	✔ (ホームルーター のビルトインセキ ュリティ機能により 検知可能)	✖	✖	✔
オンパス(on-path) の DNS 攻撃	✖	✖	✖	✖	✔	✔	✖	✖	✖	✖	✖	✖	✖	✖	✔ (pDNS がログニングして おり、解決パスが検査 可能な場合のみ)
DNS に対する DoS	✖	✖	✔ (攻撃が権 威サーバー に対するも のである場 合)	✖	✔ (攻撃が再帰リゾルバー または権威サーバーに 対するもので、かつログ ニング、NetFlow/Zee k 等によるトラフィック分析を 行っている場合)	✔ (NetFlow/ Zeek 等によ るトラフィッ ク分析を行 っている場 合)	✖	✖	✖	✖	✖	✖	✔	✖	✔
DoS を目的とした DNS サーバーの 不正使用	✖	✖	✔ (攻撃が権 威サーバー の応答を利 用している 場合)	✖	✔ (攻撃が再帰リゾルバー または権威サーバーに 対するもので、かつログ ニング、NetFlow/Zee k 等によるトラフィック分析を 行っている場合)	✔ (NetFlow/ Zeek 等によ るトラフィッ ク分析を行 っている場 合)	✖	✖	✖	✔	✖	✖	✔	✖	✔

レジストラー

レジストリ

権威 DNS
サーバー運
用者

ドメイン名
リセラー

再帰リゾルバー運用者

ネットワーク
運用者

アプリケー
ションサービ
スプロバイ
ダー

ホスティング
プロバイダー

脅威インテ
リジェンスプ
ロバイダー

機器、OS、
アプリケー
ションソフト
ウェアの開
発者

ドメイン登録者

エンドユーザー

法執行機および
公安機関

CSIRTs /
ISACs

インシデント対応者

動的な DNS 解決 による検知の難 化	✖	✔ (eSLD のみ)	✖	✖	✔	✖	✖	✖	✔	✖	該当なし (登録者が脅威ア クターそのもの)	✔ (アンチウイルスソ フトウェアで検知 可能)	✔	✖	✔ (pDNS がロギングして いるか、この攻撃手法 が健在で解決が進行し ていると想定)
動的な DNS 解決 (Fast flux)による 隠ぺい	✖	✔ (eSLD のみ)	✔ (eSLD の み。短い TTL にフラ グを設定し て詳細な分 析を行って いる場合)	✖	✔ (NetFlow/Zeek 等によ るトラフィック分析を行っ ている場合)	✖ (pDNS が無 ければ検知 不可)	✖	✖	✔	✖	該当なし (登録者が脅威ア クターそのもの)	✔ (アンチウイルスソ フトウェアで検知 可能)	✔	✖	✔ (pDNS がロギングして いるか、この攻撃手法 が健在で解決が進行し ていると想定)
DNS を介した情 報の不正な持ち 込みおよび持ち出 し	✖	✖	✖	✖	✖	✖ (トラフィック 分析を行っ ていない場 合は検知不 可)	✖	✖	✔	✖	該当なし (登録者が脅威ア クターそのもの)	✖	✔	✖	✔ (pDNS がロギングして いると想定)
(実効的)セカンド レベルドメインの 悪意ある登録	✔ (eSLD のみ。ドメイン 作成時点および存在 中に分析を行って いる場合)	✔	✔ (登録された 文字列によ る)	✔	✔ (pDNS 分析を行って いる場合)	✖	✔	✖	✔	✖	該当なし (登録者が脅威ア クターそのもの)	✖	✔ (レジストラーに連 絡し、レジストリへ のエスカレーショ ンを要請)	✖	✖ (登録の検知はできな い)
ダイナミック DNS プロバイダーを介 した悪意あるサブ ドメインの作成	✖	✖	✔	✖	✔ (DNS RPZ を使用し、脅 威インテリジェンスを反 映している場合)	✖	✔	✖	✔	✖	該当なし (登録者が脅威ア クターそのもの)	✖	✔	✖	✖ (名前の作成は検知で きない)
DNS の不正使用 を目的とした DNS 以外のサーバー の侵害	✖	✖	✖	✖	✖	✖	✖	✔ (防弾ホスティ ングでない場 合)	✔	✖	✖	✖	✔	✖	✔

	レジストラー	レジストリ	権威 DNS サーバー運 用者	ドメイン名 リセラー	再帰リゾルバー運用者	ネットワーク 運用者	アプリケー ションサービ スプロバイ ダー	ホスティング プロバイダー	脅威インテ リジェンスプ ロバイダー	機器、OS、 アプリケーションソフト ウェアの開 発者	ドメイン登録者	エンドユーザー	法執行機および 公安機関	CSIRTs / ISACs	インシデント対応者
未登録ドメイン名 を介したなりすまし	✖	✖	✔	✖	✔ (DNS ログ分析や NetFlow/Zeek 等による トラフィック分析を行って いる場合)	✖	✖	✔ (防弾ホスティ ングでない場 合)	✔	✖	✖		✔	✖	✔
登録されたドメイ ン名のなりすまし	✖	✔	✖	✖	✔ (DNS 応答の分析を行 い RFC 8914 規定の拡 張エラーを有効にして いる場合)	✖	✔	✔ (防弾ホスティ ングでない場 合)	✔	✖	✖ (DMARC を使用し ていない場合)	✖	✔	✖	✔ (DMARC を使用してい るか、pDNS による分析 を行っている想定)
DNS トンネリング	✖	✖	✖	✖	✔ (NetFlow/Zeek 等によ るトラフィック分析を行っ ている場合)	✖ (トラフィック 分析を行っ ていない場 合)	✖	✖	✔	✖	✖	✖	✖	✖	✖ (pDNS は理論上これを 検知できるが、極めて 困難)
DNS ビーコン	✖	✔	✖	✖	✔ (NetFlow/Zeek 等によ るトラフィック分析を行っ ている場合)	✖	✖	✖	✔	✖	✖	✖	✔	✖	✔ (C2 チャネルを使用す る機器があると認識し ている場合、pDNS を使 用する)

緩和

- 🟢 : エンティティは検知する能力を保持している
- 🔴 : エンティティは検知する能力が無い

	レジストラー	レジストリ	権威 DNS サーバー運 用者	ドメイン名 リセラー	再帰リゾルバー運用者	ネットワーク 運用者	アプリケー ションサービ スプロバイ ダー	ホスティング プロバイダー	脅威インテ リジェンスプ ロバイダー	機器、OS、 アプリケー ションソフト ウェアの開 発者	ドメイン登録者	エンドユーザー	法執行機および 公安機関	CSIRTs / ISACs	インシデント対応者
DGA (ドメイン生成 アルゴリズム)	🟢 (ステータスを onHold に更新する、または ネームサーバーを変 更する)	🟢	🔴	🟢 (ステータス を onHold に 更新する、 またはネー ムサーバー を変更する)	🟢 (DNS RPZ を使用する)	🔴	🔴	🔴	🔴	🔴	該当なし (登録者が脅威ア クターそのもの)	🔴	🟢 (防衛的登録。ドメ インを生成し複数 レジストリで同じも のを登録する)	🔴	🟢 (ブロッキングを行う)
ドメイン名の侵害	🟢 (侵害がレジストラレ ベルで行われている 場合)	🟢	🟢	🟢 (侵害がリセ ラーレベル で行われて いる場合)	🟢	🔴	🔴	🔴	🔴	🔴	🟢 (適切に不正を排 除する)	🔴	🔴	🔴	🟢 (ブロッキングを行う)
lame delegation (レイムデレゲー ション)	🔴	🔴	🔴	🔴	🔴	🔴	🔴	🔴	🔴	🔴	🟢 (ネームサーバー を更新する)	🔴	🔴	🔴	🔴 レジストラーなどに連 絡を推奨
DNS キャッシュポ イズニング	🔴	🔴	🟢	🔴	🟢 (DNSSEC 署名検証を 行う)	🟢	🔴	🔴	🔴	🔴	🔴	🔴	🔴	🔴	🔴 (権威サーバー運用 者などに連絡を推奨
DNS リバインディ ング	🔴	🟢	🔴	🔴	🔴	🟢 (BCP38 を 適用する、 攻撃者の IP ネットプロッ クを BGP で ブラックホー ルに吸い込 む)	🔴	🔴	🔴	🔴	🔴	🔴	🔴	🔴	🟢

	レジストラー	レジストリ	権威 DNS サーバー運 用者	ドメイン名 リセラー	再帰リゾルバー運用者	ネットワーク 運用者	アプリケー ションサービ スプロバイ ダー	ホスティング プロバイダー	脅威インテ リジェンスプ ロバイダー	機器、OS、 アプリケー ションソフト ウェアの開 発者	ドメイン登録者	エンドユーザー	法執行機および 公安機関	CSIRTs / ISACs	インシデント対応者
DNS サーバーの 侵害	✖	✖	✔	✖	✔ (再帰リゾルバー自身を 自分達で運用している 場合のみ)	✖	✖	✖	✖	✖	✖	✖	✖	✖	✔
スタブリゾルバー のハイジャック	✖	✖	✖	✖	✖	✖	✖	✖	✖	✔	✖	✔ (アンチウイルスソ フトウェアで PC を スキャンする)	✖	✖	✔
ローカルな再帰リ ゾルバーのハイジ ャック	✖	✖	✖	✖	✖	✔ (悪意ある DNS サーバ ー宛の送出 トラフィック をブロックす る)	✖	✖	✖	✖	✖	✔ (ホームルーター をリポートまたは 初期化する)	✖	✖	✔
オンパス(on-path) の DNS 攻撃	✖	✖	✖	✖	✖	✔	✖	✖	✖	✖	✖	✖	✖	✖	✖ (ネットワーク運用者 などに連絡を推奨)
DNS に対する DoS	✖	✔	✖	✖	✖	✔ (攻撃者の IP ネットプロ ックを BGP でブラックホ ールに吸い 込む)	✖	✖	✖	✖	✖	✖	✖	✖	✔
DoS を目的とした DNS サーバーの 不正使用	✖	✔	✔	✖	✔	✖	✖	✖	✖	✖	✖	✖	✖	✖	✔
動的な DNS 解決 による検知の難化	✖ (eSLD の登録サービ スを提供しているに 過ぎないため)	✖	✖	✖	✔	✖	✖	✖	✖	✖	該当なし (登録者が脅威ア クターそのもの)	✖	✖	✖	✔ (詳細が特定できて いるならブロッキング を行う)

レジストラー

レジストリ

権威 DNS
サーバー運
用者

ドメイン名
リセラー

再帰リゾルバー運用者

ネットワーク
運用者

アプリケー
ションサービ
スプロバイ
ダー

ホスティング
プロバイダー

脅威インテ
リジェンスプ
ロバイダー

機器、OS、
アプリケーションソフト
ウェアの開
発者

ドメイン登録者

エンドユーザー

法執行機および
公安機関

CSIRTs /
ISACs

インシデント対応者

動的な DNS 解決 (Fast flux)による 隠ぺい	⊙ (十分迅速に行動で きる場合)	⊙ (十分迅速に行 動できる場合)	⊗	⊙ (十分迅速に 行動できる 場合)	⊙	⊙	⊗	⊗	⊗	⊗	該当なし (登録者が脅威ア クターそのもの)	⊗	⊗	⊗	⊙
DNS を介した情報 の不正な持ち込 みおよび持ち出し	⊗	⊗	⊗	⊗	⊙	⊗	⊗	⊗	⊗	⊗	該当なし (登録者が脅威ア クターそのもの)	⊗	⊗	⊗	⊙
(実効的)セカンド レベルドメインの 悪意ある登録	⊙ (ステータスを onHold に更新する、または ネームサーバーを変 更する)	⊙	⊗	⊙ (ステータス を onHold に 更新する、 またはネー ムサーバー を変更する)	⊙	⊗	⊗	⊗	⊗	⊗	該当なし (登録者が脅威ア クターそのもの)	⊗	⊙ (レジストラー/レジ ストリへの通知、 (法執行機関によ る)ドメインの押収)	⊗	⊗ (登録それ自体には 対処できない)
ダイナミック DNS プロバイダーを介 した悪意あるサブ ドメインの作成	⊗ (eSLD の登録サービ スを提供しているに 過ぎないため)	⊗	⊙	⊗	⊙	⊗	⊗	⊗	⊗	⊗	該当なし (登録者が脅威ア クターそのもの)	⊗	⊗	⊗	⊗ (作成それ自体には 対処できない)
DNS の不正使用 を目的とした DNS 以外のサーバー の侵害	⊗	⊗	⊗	⊗	⊗	⊗	⊙	⊙ (防弾ホスティ ングでない場 合)	⊗	⊗	⊗	⊗	⊗	⊗	⊙ (サーバーの修正が チームの職責範囲で ある場合)
未登録ドメイン名 を介したなりすま し	⊗	⊗	⊙	⊗	⊙	⊗	⊗	⊙ (防弾ホスティ ングでない場 合)	⊗	⊗	⊗	⊗	⊗	⊗	⊗
登録されたドメイ ン名のなりすまし	⊙ (ドメイン作成時点ま たは存在中に分析を 行っている場合)	⊗	⊗	⊙ (ドメイン作 成時点また は存在中に 分析を行っ ている場合)	⊙	⊗	⊗	⊙ (防弾ホスティ ングでない場 合)	⊗	⊗	⊙ (状況に応じて通 報するか、UDRP または URS を申 し立てる)	⊗	⊗	⊗	⊗ (DMARC を適用して いても、なりすましは 止められない)

レジストラー	レジストリ	権威 DNS サーバー運 用者	ドメイン名 リセラー	再帰リゾルバー運用者	ネットワーク 運用者	アプリケー ションサービ スプロバイ ダー	ホスティング プロバイダー	脅威インテ リジェンスプ ロバイダー	機器、OS、 アプリケーションソフト ウェアの開 発者	ドメイン登録者	エンドユーザー	法執行機および 公安機関	CSIRTs / ISACs	インシデント対応者
--------	-------	-----------------------	---------------	------------	---------------	--------------------------------	------------------	--------------------------	--------------------------------------	---------	---------	-----------------	-------------------	-----------

DNS トンネリング	✖	✖	✖	✖	✔	✖	✖	✖	✖	✖	該当なし (登録者が脅威ア クターそのもの)	✖	✖	✖	✔
DNS ビーコン	✖ (C2 ドメインはインフ ラに過ぎないため)	✖	✖	✔ (C2 ドメイン はインフラに 過ぎないた め)	✔	✖	✖	✖	✖	✖	該当なし (登録者が脅威ア クターそのもの)	✖	✔	✖	✔

抑止

- : エンティティは検知する能力を保持している
- : エンティティは検知する能力が無い

レジストラー

レジストリ

権威 DNS
サーバー運
用者

ドメイン名
リセラー

再帰リゾルバー運用者

ネットワーク
運用者

アプリケー
ションサービ
スプロバイ
ダー

ホスティング
プロバイダ
ー

脅威インテ
リジェンスプ
ロバイダー

機器、OS、
アプリケー
ションソフト
ウェアの開
発者

ドメイン登録者

エンドユーザー

法執行機および
公安機関

CSIRTs /
ISACs

インシデント対応者

DGA (ドメイン生成アルゴリズム)	(eSLD のみ。ドメイン作成時点および存在中に分析を行う)	(eSLD のみ)	(DGA が既知の場合)	(eSLD のみ。ドメイン作成時点および存在中に分析を行う)	(DGA が既知であれば、DNS RPZ を使用し脅威インテリジェンスを反映する)	(DGA が既知の場合)					該当なし (登録者が脅威アクターそのもの)			(DGA の調査)	
ドメイン名の侵害	(登録者アカウントの侵害を抑止する対策を講じる)			(登録者アカウントの侵害を抑止する対策を講じる)							(登録者アカウントの侵害を抑止する事前防御策を講じる)			(関連するステークホルダーに連絡する)	
lame delegation (レイムデレゲーション)											(ドメインポートフォリオを管理するための優れた実践を導入する)			(関連するステークホルダーに連絡する)	
DNS キャッシュポイズニング					(再帰リゾルバーで DNSSEC 署名検証を有効にする)									(再帰リゾルバー運用者またはネットワーク運用者に連絡し、キャッシュのクリア/リフレッシュを確認)	(キャッシュは組織外にあると想定)

レジストラー レジストリ 権威 DNS
サーバー運
用者 ドメイン名
リセラー 再帰リゾルバー運用者 ネットワーク
運用者 アプリケー
ションサービ
スプロバイ
ダー ホスティング
プロバイダ
ー 脅威インテ
リジェンスプ
ロバイダー 機器、OS、
アプリケー
ションソフト
ウェアの開
発者 ドメイン登録者 エンドユーザー 法執行機および
公安機関 CSIRTs /
ISACs インシデント対応者

DNS リバインディ ング												 (ホームルーター に強力なパスワー ドを設定するか、 ブラウザのセキ ュリティ機能に頼 る)		 (脆弱な/改ざ んされた Web サイトについて 調整を行う)	
DNS サーバーの 侵害			 (権威サーバ ーが侵害さ れた場合)		 (再帰リゾルバー自身が 侵害された場合)									 (関連するステ ークホルダー に連絡する)	 (サーバーは組織外に あると想定)
スタブリゾルバー のハイジャック												 (ブラウザやアド オンツール等を最 新の状態に保つ)		 (エンドユーザ ーの注意を喚 起する)	
ローカルな再帰リ ゾルバーのハイジ ヤック						 (NetFlow/ Zeek による トラフィック 分析を行 い、脅威イ ンテリジェ ンスの提供を 受ける)						 (ソフトウェアを最 新の状態に保ち、 強力なパスワード を設定するなど)		 (エンドユーザ ーの注意を喚 起する)	
オンパス(on-path) の DNS 攻撃														 (情報を共有し 関心を高める)	 (DNSSEC 署名検証を 有効にする)

	レジストラー	レジストリ	権威 DNS サーバー運 用者	ドメイン名 リセラー	再帰リゾルバー運用者	ネットワーク 運用者	アプリケー ションサービ スプロバイ ダー	ホスティング プロバイダ ー	脅威インテ リジェンスプ ロバイダー	機器、OS、 アプリケー ションソフト ウェアの開 発者	ドメイン登録者	エンドユーザー	法執行機および 公安機関	CSIRTs / ISACs	インシデント対応者
DNS に対する DoS	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✔	✔ (オープンリゾ ルバーおよび 感染した機器 について調整 を行う)	✖ (BCP 38 は IR の職責 範囲ではないと想定)
DoS を目的とした DNS サーバーの 不正使用	✖	✖	✔ (攻撃が権 威サーバー の応答を利用 している 場合)	✖	✔ (ACL やレート制限など を適用する)	✖	✖	✖	✖	✔	✖	✔ (ファームウェアを 最新の状態に保 ち、適切な設定を 行うなど)	✔ (踏み台となってい る DNS サーバー を特定するためナ ショナルレベルの CERT に関与を要 請)	✔ (オープンリゾ ルバーおよび 感染した機器 について調整 を行う)	✔ (感染した機器をクリー ンアップする)
動的な DNS 解決 による検知の難 化	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✔	✔ (関連するステ ークホルダー に連絡する)	✖
動的な DNS 解決 (Fast flux)による 隠ぺい	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✔	✔ (関連するステ ークホルダー に連絡する)	✖
DNS を介した情 報の不正な持ち 込みおよび持ち出 し	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✖	✔	✔ (情報を共有し 関心を高める)	✔
(実効的)セカンド レベルドメインの 悪意ある登録	✔ (eSLD のみ。ドメ イン作成時に分析 を行う)	✔	✖	✔ (eSLD の み。ドメイン 作成時に分 析を行う)	✖	✖	✖	✖	✖	✔	該当なし (登録者が脅威ア クターそのもの)	✖	✔ (レジストラーに通 知し、レジストリへ のエスカレーシ ョンを要請)	✔ (関連するステ ークホルダー に連絡する)	✖

	レジストラー	レジストリ	権威 DNS サーバー運 用者	ドメイン名 リセラー	再帰リゾルバー運用者	ネットワーク 運用者	アプリケー ションサービ スプロバイ ダー	ホスティング プロバイダ ー	脅威インテ リジェンスプ ロバイダー	機器、OS、 アプリケー ションソフト ウェアの開 発者	ドメイン登録者	エンドユーザー	法執行機および 公安機関	CSIRTs / ISACs	インシデント対応者
ダイナミック DNS プロバイダーを介 した悪意あるサブ ドメインの作成	✖	✖	✖	✖	✖	✖	✖	✖	✖	✔	該当なし (登録者が脅威ア クターそのもの)	✖	✔	✔ (関連するステ ークホルダー に連絡する)	✖
DNS の不正使用 を目的とした DNS 以外のサーバー の侵害	✖	✖	✖	✖	✖	✖	✔ (防弾ホステ ィングでない 場合)	✔ (防弾ホステ ィングでない 場合)	✖	✖	✖	✖	✔	✔ (情報を共有し 関心を高める)	✔ (パッチ管理などを行う)
未登録ドメイン名 を介したなりすま し	✖	✔	✖	✖	✖	✖	✖	✔ (防弾ホステ ィングでない 場合)	✖	✖	✖	✖	✔	✔ (情報を共有し 関心を高める)	✖
登録されたドメイ ン名のなりすまし	✔ (eSLD のみ。ドメ イン生成時に分析 を行う)	✖	✔ (偽装ドメイ ンがサービ ス対象とな り解決が行 われるのを 防止する)	✔ (eSLD の み。ドメイ ン生成時に分 析を行う)	✖	✖	✖	✔ (防弾ホステ ィングでない 場合)	✖	✔	該当なし (登録者が脅威ア クターそのもの)	✖	✔	✔ (情報を共有し 関心を高める)	✖
DNS トンネリング	✖	✖	✖	✖	✔ (JA3、JA3S による TLS フィンガープリント採取、 NetFlow/Zeek 等による トラフィック分析を行う)	✔ (NetFlow/ Zeek による トラフィック 分析を行 い、脅威イ ンテリジェ ンスの提供を 受ける)	✖	✖	✖	✖	✖	✖	✔	✔ (感染した機器 のクリーンアッ プおよびマル ウェアの分析を 行う)	✖ (ファイアウォールのル ール管理はは IR の職 責範囲ではないと想定)
DNS ビーコン	✖	✖	✖	✖	✔ (NetFlow/ Zeek による トラフィック分析を行う)	✔ (NetFlow/ Zeek による トラフィック 分析を行 い、脅威イ ンテリジェ ン	✖	✖	✖	✖	✖	✖	✔	✔ (感染した機器 のクリーンアッ プおよびマル ウェアの分析を 行う)	✖

レジストラー	レジストリ	権威 DNS サーバー運 用者	ドメイン名 リセラー	再帰リゾルバー運用者	ネットワーク 運用者	アプリケー ションサービ スプロバイ ダー	ホスティング プロバイダ ー	脅威インテ リジェンスプ ロバイダー	機器、OS、 アプリケー ションソフト ウェアの開 発者	ドメイン登録者	エンドユーザー	法執行機および 公安機関	CSIRTs / ISACs	インシデント対応者
--------	-------	-----------------------	---------------	------------	---------------	--------------------------------	----------------------	--------------------------	--	---------	---------	-----------------	-------------------	-----------

スの提供を
受ける)

Acknowledgements

SIG members

Andrey Meshkov (AdGuard)
Ángel González (INCIBE-CERT)
Angela Matlapeng (bwCSIRT)
Benedict Addis (Shadowserver)
Brett Carr (Nominet)
Carlos Alvarez (ICANN; founding member)
David Ruefenacht (Infoguard)
Gabriel Andrews (FBI)
John Todd (Quad9; current co-chair of DNS Abuse SIG)
Jonathan Matkowsky (RiskIQ / Microsoft; former co-chair)
Jonathan Spring (CISA; current co-chair of DNS Abuse SIG)
Mark Henderson (IRS)
Mark Svancarek (Microsoft)
Merike Kaeo (Double Shot Security)
Michael Hausding (SWITCH-CERT; former co-chair, current FIRST board member)
Peter Lowe (current co-chair of DNS Abuse SIG)
Shoko Nakai (JPCERT/CC)
Swapneel Patnekar (Shreshta IT)
Trey Darley (FIRST board; founding member)

SIG chairs

Current: Jonathan Spring, John Todd, Peter Lowe
Former: Michael Hausding, Jonathan Matkowsky

Special Thanks

To Carlos Alvarez (ICANN) for an initial start on the abuse technique types matrix.

Translation: Professionally outsourced

Review: Shoko Nakai, Yukako Uchida, JPCERT/CC, (and volunteers from DNSOPS.JP)

DNS Abuse Techniques Matrix

<https://www.first.org/global/sigs/dns/>

20 of 22